CYBER RISK ASSESSMENT

INSTRUCTOR'S PROFILE

CPT DANSAN M CAMUA (SC) PA

CO, CYBER PROTECTION AND DETECTION COMPANY, CYBER BN, SR, PA



Education:

- OCC CL 45 – 2015 "NAHIRANG"
- SOAC 47 – 2022
- SOBC 44 - 2018

Certification:

- EC- Council Certified Incident Handler
- Certified Cyber Operation
- Cyber Threat Intelligence Management NCIII
- Data Analytics NCIII

Training/Exercises:

- PA-RTA Cybersecurity SMEE
- CYBEREX
- EXERCISE KAHITAN 2025
- AJEX 2025

ROADMAP

- **Diagnose** the following:
  - Purpose and Applicability
  - Target Audience
  - Risk Management Process
  - Risk Assessment
  - Key Risk Concepts
  - Application of Risk Assessment.
  - Preparing Risk Management
  - Conduct of Risk Assessment
  - Risk Management Sharing
- **Experiment:** check on learning
- **Reflect:** takeaways on the lesson
- **Evaluate:** Written Examination (Multiple response)

LEARNING OUTCOME

At the end of this subject, the **students will be able to apply cyber risk assessments** in cyberspace during army operations in accordance with PAM 6-0102-4.

REFERENCE

- PAM 6-00 **Command and Control Communications and Cyber Systems**
- PAM 6-0102 – **Signal Operations**
- PAM 3-00 - **Army Operations**
- PAM 6-0102-04 **Cyberspace Operation**

SAFETY PRECAUTION



The nearest person on the fire extinguisher will extinguish and control the fire. The facilitator will be the last person to leave the classroom. Consolidation point will be Infront of Yan Hall.

SAFETY PRECAUTION



In case of earthquake: **"DROP, COVER AND HOLD ON."** and the emergency evacuation plan before the start of the training and ensure that the learner understands.



SAFETY PRECAUTION



Learner to be *observant of broken electrical wires*.

“SAFETY in mind, leave accidents behind.”


THINK
OUR AIM . . .
NO ACCIDENTS

CLASSROOM RULES

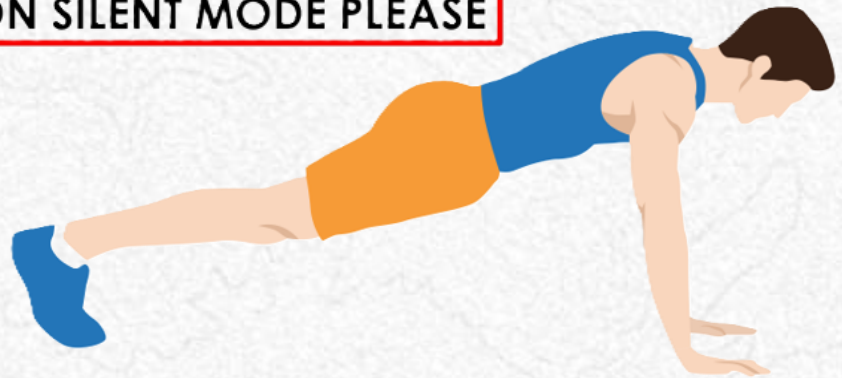




ON SILENT MODE PLEASE







QUOTES FOR THE DAY

"Cybersecurity is not just about **protecting computers and networks**. It is about **protecting the mission**, the **information**, and the **lives** that depend on them."

CYBER RISK ASSESSMENT

Studying and **understanding cyber risk assessments** in order to **maintain security**, **effectiveness**, and **readiness** in a world facing increasingly serious and sophisticated cyber threats for the **Philippine Army**.

Cyber Risk Assessment Introduction

Purpose and Applicability

Basically, the purpose and scope of the Philippine Army Cyber Risk Assessment are focused on the security, resiliency, and capacity of the military's digital infrastructure towards supporting its vital missions.

Cyber Risk Assessment Introduction

Target Audience

The SR, PA shall conduct CRA for **PA Major Units** (PAMUs) and **General/Personal/Special Staff offices** while Territorial Signal Battalions (through its CSIRT) shall conduct CRA on its r**espective PAMU sub-units** and **offices**.

Cyber Risk Assessment Introduction

Key Risk Concepts: **The CIA Triad**

Cybersecurity protects the three pillars of information, the CIA Triad:

- **Confidentiality** – Only those with authorized access can obtain the information
- **Integrity** – Data must be authentic and reliable; any attempt to alter it must be detectable
- **Availability** – Data and systems must be accessible and functional whenever needed.

Cyber Risk Assessment Introduction

Key Risk Concepts: **Asset, Threat, Vulnerability, Risk**

- **Asset –** Anything of value to the unit: classified data, command and control systems, and communication networks.
- **Threat –** A potential cause of an unwanted incident: state-sponsored actors, criminals, insiders, or natural disasters.
- **Vulnerability –** A weakness in the security posture that a threat can exploit.
- **Risk –** The likelihood that a threat exploits a vulnerability, combined with its impact on the mission.

Risk assessment identifies the assets, the threats against them, and the vulnerabilities that expose them, then prioritizes cost-effective actions to reduce the risk.

Cyber Risk Assessment Introduction

Cyber Threats

1 **Advanced Persistent Threats (APTs)**

These are sophisticated and persistent attacks launched by state-sponsored or highly organized groups, often targeting critical infrastructure or sensitive data.

2 **Malware and Viruses**

These malicious software programs can steal data, disrupt operations, or take control of systems, posing a significant risk to military networks.

3 **Data Breaches and Leaks**

The theft or unauthorized disclosure of sensitive information, such as classified documents, troop movements, or operational plans, can have dire consequences.

4 **Denial-of-Service (DoS) Attacks**

These attacks aim to overwhelm systems with traffic, causing them to become unavailable and disrupting critical military functions.

Fundamentals of Risk Assessment

Risk Management Process

Three (3) Periods, Six (6) Phases

The Risk Management Process is performed collaboratively by the **Blue**, **Purple**, and **Red** Teams across three (3) periods:

- **Pre-Cyber Incident –** Phase 1: *Preparation*; Phase 2: Identification
- **During Incident –** Phase 3: Containment; Phase 4: Eradication
- **Post Incident –** Phase 5: Recovery; Phase 6: Assessment and Review

Fundamentals of Risk Assessment

Risk Management Process

PRE-CYBER INCIDENT

Phase 1 – Preparation:

The Preparation Phase is the most important phase of the incident response process. It determines the success of the CIRT in performing its task by ensuring the readiness of people, tools, and procedures.

Fundamentals of Risk Assessment

Risk Management Process

PRE-CYBER INCIDENT

Phase 2 – Identification:

The Identification Phase is crucial in the incident response process. The ability to detect and identify a cyber incident early determines its impact and gravity, since time is essential in response.

Fundamentals of Risk Assessment

Risk Management Process

DURING-CYBER INCIDENT

Phase 3 – Containment:

The objective of the Containment Phase is to control the situation and limit the extent of the damage. This ensures that the incident does not spread to other systems and assets.

Fundamentals of Risk Assessment

Risk Management Process

DURING-CYBER INCIDENT

Phase 4 – Eradication:

In the Eradication Phase, all components and symptoms of the incident must be removed and addressed. The CSIRT must then conduct validation to prevent the recurrence of the incident.

Fundamentals of Risk Assessment

Risk Management Process

POST-CYBER INCIDENT

Phase 5 – Recovery:

In the Recovery Phase, the Blue, Purple, and Red Teams are involved, while the PA Cyber Battle Staff and other PA CIRTs continue to monitor the progress of the incident. This phase covers the steps required to restore data and systems to a healthy working state, allowing normal unit operations.

Fundamentals of Risk Assessment

Risk Management Process

POST-CYBER INCIDENT

Phase 6 – Assessment and Review:

In the Assessment and Review Phase, the Purple, Blue, and Red Teams are involved. The CIRT prepares the necessary documentation, such as the After Activity Report and Special Report, for submission to Higher Headquarters and the PA Cyber Battle Staff, and for the awareness of other PA CIRTs.

Cyber Risk Assessment Process

Conduct of Risk Assessment: **SANS Controls 1-5**

The conduct of CRA is anchored on the SANS 20 Critical Security Controls, applied as applicable to the unit. Controls 1 to 5 establish the foundation:

1. **Inventory of Authorized and Unauthorized Devices –** Maintain an up-to-date inventory of all devices connected to PANET so attackers cannot exploit unknown or unprotected systems.
2. **Inventory of Authorized and Unauthorized Software –** Keep a list of authorized software per system and track installations to detect unauthorized or malicious programs.
3. **Secure Configurations for Hardware and Software –** Build, validate, and maintain secure standard images for all workstations, laptops, servers, and mobile devices.
4. **Continuous Vulnerability Assessment and Remediation –** Run automated vulnerability scans regularly and fix critical findings within 48 hours.
5. **Malware Defenses –** Deploy automatically updated endpoint security on all machines and disable auto-run for removable media.

Cyber Risk Assessment Process

Conduct of Risk Assessment: **SANS Controls 6-10**

Controls 6 to 10 secure applications, wireless access, data, people, and network devices:

6. **Application Software Security –** Test in-house and third-party applications for security flaws and deploy web application firewalls that inspect all traffic.
7. **Wireless Device Control –** Allow only wireless devices with an authorized configuration, security profile, and documented owner; scan for rogue access points.
8. **Data Recovery Capability –** Automatically back up all systems at least weekly (sensitive systems more often) and regularly test restoration.
9. **Security Skills Assessment and Training –** Find knowledge gaps and fill them with appropriate training mapped to each role.
10. **Secure Configurations for Network Devices –** Harden firewalls, routers, and switches against approved standards; document and approve any deviation.

Cyber Risk Assessment Process

Conduct of Risk Assessment: **SANS Controls 11-15**

Controls 11 to 15 control access into, across, and within the network:

11. **Limitation and Control of Network Ports, Protocols, and Services –** Block traffic that is not explicitly allowed and limit remote access to legitimate users and services.
12. **Controlled Use of Administrative Privileges –** Protect and validate administrative accounts and enforce robust passwords.
13. **Boundary Defense –** Establish multi-layered defenses using firewalls, proxies, and DMZ perimeter networks; filter inbound and outbound traffic.
14. **Maintenance, Monitoring, and Analysis of Audit Logs –** Generate standardized logs on dedicated servers and review them regularly to uncover attacks.
15. **Controlled Access Based on the Need to Know –** Classify data by impact of exposure and restrict non-public data to authenticated users only.

Cyber Risk Assessment Process

Conduct of Risk Assessment: **SANS Controls 16-20**

Controls 16 to 20 sustain vigilance and validate the defense:

16. **Account Monitoring and Control –** Disable dormant accounts and immediately revoke access of separated personnel to stop impersonation.
17. **Data Loss Prevention –** Monitor the movement of data across network boundaries, electronically and physically, to stop unauthorized transfer.
18. **Incident Response and Management –** Maintain an Incident Response Plan with clearly delineated roles to discover, contain, and eradicate attacks.
19. **Secure Network Engineering –** Use a robust three-tier architecture (DMZ, middleware, private network) that resists circumvention.
20. **Penetration Tests and Red Team Exercises –** Use simulated attacks to identify vulnerabilities and gauge readiness of defenses and response.

Cyber Risk Assessment Process

Application of Risk Assessment: **PPT Framework**

The CRA evaluates the cybersecurity posture of a unit against criteria grouped under the People-Process-Technology (PPT) Framework:

- **People –** Cyber training and awareness of personnel; designation of ISO/ISNCO and certified CIRT personnel; password discipline and safe use of personal devices and social media.
- **Process –** How ICT is used, maintained, and governed: authorized communication platforms, data back-up and recovery, policies, VAPT of unit systems, and cybersecurity awareness training.
- **Technology –** Compliance of hardware and software: licensed and updated operating systems and applications, no unauthorized software, and regular maintenance of ICT equipment.

A unit, office, or workstation is rated HIGH, MEDIUM, or LOW risk based on the criteria present under each element.

Cyber Risk Assessment Process

Cyber Risk Scale and Formula

RISK SCALE

- **HIGH –** 51% to 100%
- **MEDIUM –** 11% to 50%
- **LOW –** 1% to 10%

RISK FORMULA

- **Per element (People, Process, Technology) –** Risk Output x Points Allocated / 100, where High = 50 pts, Medium = 40 pts, Low = 10 pts.
- **Overall Cybersecurity Posture –** People + Process + Technology.

SUMMARY

- ✓ Cyber Risk Assessment Introduction and Key Risk Concepts
- ✓ Fundamentals: Risk Management Process (6 Phases)
- ✓ Conduct of CRA: SANS 20 Critical Security Controls
- ✓ Application: PPT Framework, Risk Scale and Formula

LEARNING OUTCOME

By this time, the **students will be able to apply cyber risk assessments** in cyberspace during army operations in accordance with PAM 6-0102-4.

CHECK ON LEARNING

1. In cybersecurity, what does CIA stand for?

a. Cybersecurity, Intelligence, and Assessment
b. Confidentiality, Integrity, and Availability
c. Cyber Intelligence Agency
d. Communication, Information, and Authentication

a. Answer: b. Confidentiality, Integrity, and Availability

CHECK ON LEARNING

2. During military operations, an unauthorized individual gains access to classified operational plans. Which cybersecurity principle has been compromised?

a. Integrity
b. Confidentiality
c. Availability
d. Accountability

Answer: b. Confidentiality

CHECK ON LEARNING

3. During a Cyber Risk Assessment, a Signal Officer discovers that a workstation is running an outdated operating system without security updates. What does this finding represent?

a. Threat
b. Vulnerability
c. Asset
d. Cyber Incident

Answer: b. Vulnerability

CHECK ON LEARNING

4. A military workstation becomes infected with malware. The Cyber Incident Response Team (CIRT) immediately isolates the affected workstation to prevent the infection from spreading. Which phase of the Risk Management Process is being performed?

a. Preparation
b. Identification
c. Containment
d. Recovery

Answer: c. Containment

CHECK ON LEARNING

5. Under the People–Process–Technology (PPT) Framework, which element is primarily affected when a unit's designated Information Security Officer (ISO) has not undergone cybersecurity training?

a. People
b. Process
c. Technology
d. Infrastructure

Answer: a. People

CHECK ON LEARNING

6. During a Cyber Risk Assessment, a military unit receives an overall cybersecurity risk score of 48%. Based on the risk scale presented in the lecture, what is the unit's risk classification?

a. Low Risk
b. Medium Risk
c. High Risk
d. Critical Risk

Answer: b. Medium Risk

CHECK ON LEARNING

7. What is the primary purpose of conducting a Cyber Risk Assessment in a military unit?

a. To increase internet speed and network connectivity
b. To identify cyber threats, vulnerabilities, and potential impacts on military operations
c. To replace outdated computers immediately
d. To monitor the daily attendance of military personnel

Answer: b. To identify cyber threats, vulnerabilities, and potential impacts on military operations

CHECK ON LEARNING

8. Which phase of the Risk Management Process focuses on restoring affected systems and returning the unit to normal operations after a cyber incident?

a. Preparation
b. Containment
c. Eradication
d. Recovery

Answer: d. Recovery

CHECK ON LEARNING

9. During a Cyber Risk Assessment, a Signal Officer discovers several unauthorized computers connected to the military network. Which security control should be prioritized to address this finding?

a. Inventory of Authorized and Unauthorized Devices
b. Data Recovery Capability
c. Security Skills Assessment and Training
d. Incident Response and Management

Answer: a. Inventory of Authorized and Unauthorized Devices

CHECK ON LEARNING

10. As a Signal Officer, what is the most appropriate action after identifying a HIGH cybersecurity risk that could affect the unit's command-and-control communication systems?

a. Ignore the findings as long as the communication system is functioning
b. Disconnect all communication systems permanently
c. Report the findings to the commander and recommend appropriate risk mitigation measures
d. Wait until an actual cyberattack occurs before taking action

Answer: c. Report the findings to the commander and recommend appropriate risk mitigation measures

FEEDBACK



FUTURE

Next lesson will be **Zero Trust Framework**



CLOSING STATEMENT

As **future Signal Officers**, remember that our responsibility goes beyond establishing communication systems. We must also ensure that these systems remain ***secure***, ***reliable***, and ***available*** whenever the mission requires them.

"Effective communication supports the mission, but secure communication protects the mission."


ATTENTION
YOUR
FOR
YOU
THANK